AULA DE PÓS-GRADUAÇÃO · **Cybersecurity**

DevSecOps: Introdução, Pesquisa, Normas e Certificações

Integrando segurança contínua, marcos regulatórios e conformidade ao pipeline de entrega

Docente

Prof. Cloves Rocha

Programa

Pós-Graduação em **Cybersecurity**

Módulo de Fundamentos, Evidências Científicas e Normativas Globais



Made with GAMMA

CONCEITO FUNDAMENTAL

Segurança entra no ciclo desde o início

O DevSecOps não é um adendo tardio ao pipeline: é a expansão deliberada do DevOps que une desenvolvimento, operações e segurança sob uma responsabilidade compartilhada.

No modelo tradicional, auditorias tardias funcionavam como gargalos operacionais e inibidoras de release. A abordagem *shift-left* antecipa testes estáticos, análise de dependências e verificação de políticas para as primeiras etapas do código.

Shift-Left · Detectar vulnerabilidades na concepção custa até 100 vezes menos que em produção.



Figura 1. A segurança passa de barreira externa a controle integrado no fluxo de entrega.

Made with GAMMA

Da cultura DevOps ao DevSecOps: linha do tempo



2009 · DevOps

DevOpsDays, em Ghent: desenvolvimento e operações orientados à velocidade.



2012–2016 · Origens

Manifesto e artigos impulsionam testes de segurança nas esteiras contínuas.



2018 · LGPD & GDPR

LGPD e GDPR exigem *privacy by design* e responsabilização por vazamentos.



2020–2022 · NIST SSDF

NIST SP 800-218 formaliza práticas de cadeia de suprimentos; pesquisa se consolida.

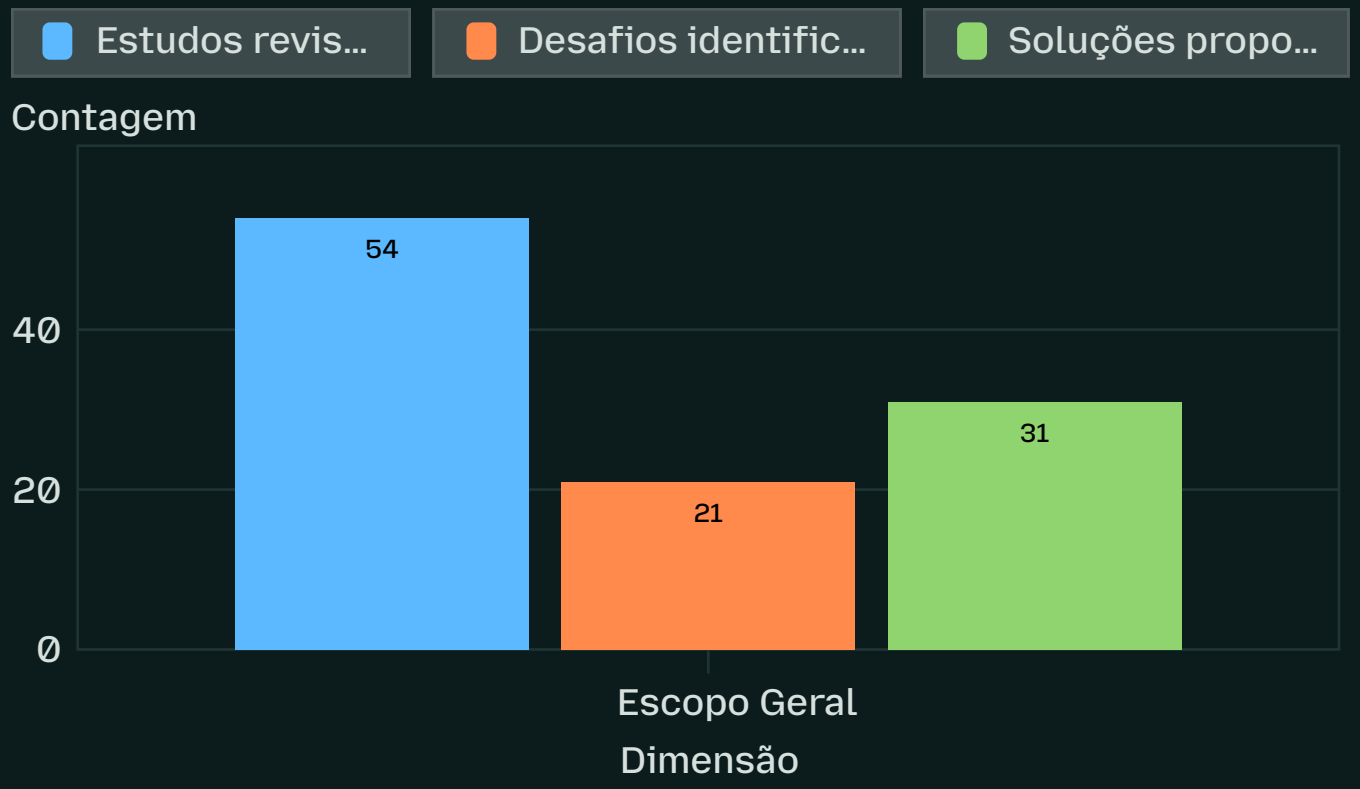
Marcos históricos da indústria e revisões sistemáticas de software (2009–2024).

Made with GAMMA

EVIDÊNCIA EMPÍRICA · REVISÃO SISTEMÁTICA

Literatura mapeia desafios em ferramentas e pessoas

Levantamento de Zhao et al. (2024) categorizou o ecossistema DevSecOps



Ferramentas são as mais documentadas; pessoas, o elo esquecido.

A revisão sistemática de 54 artigos mostra que os problemas de instrumentação e integração em CI/CD concentram a maior parte das queixas técnicas.

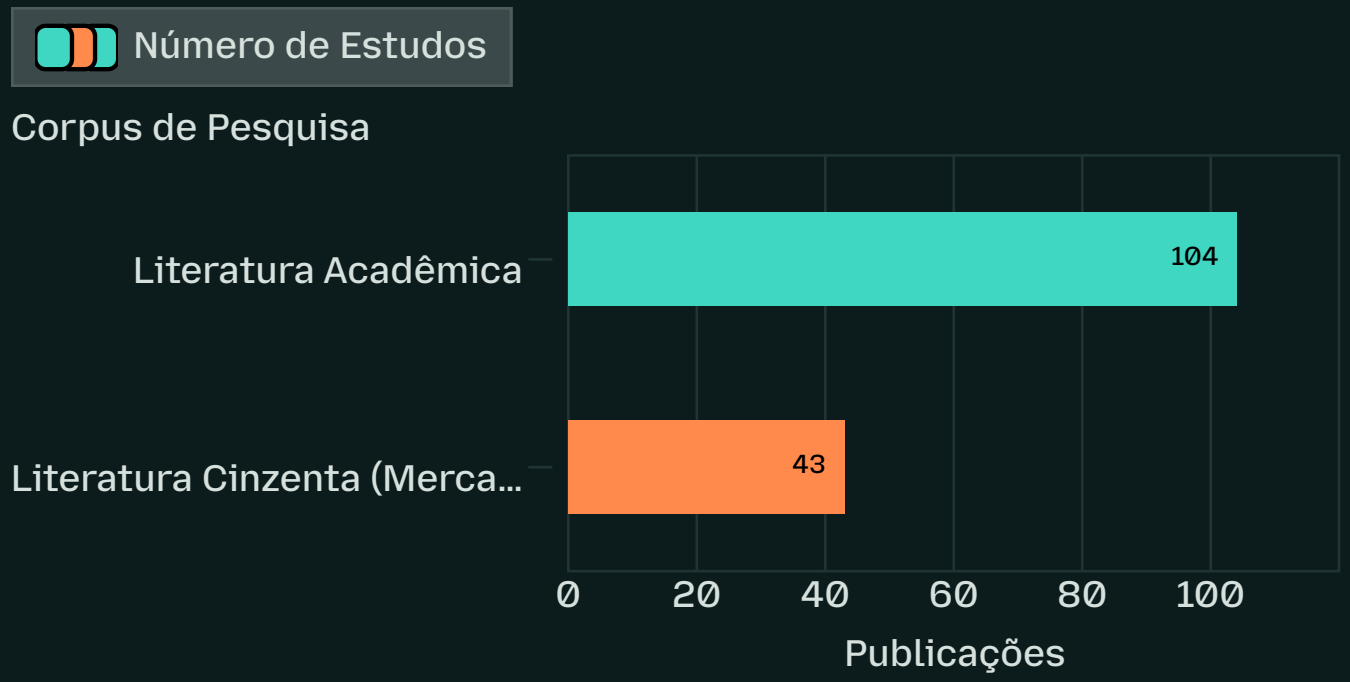
Fonte: Zhao et al. (2024), *DevSecOps: A Systematic Literature Review* (ACM Computing Surveys).

Made with GAMMA

PANORAMA MULTIVOCAL · ESTUDO DE LARGA ESCALA

Revisão multivocal cobre definições, práticas, ferramentas e métricas

Composição das fontes avaliadas no estudo multivocal (2012–2021)



147 estudos

147 estudos, sendo 104 acadêmicos e 43 de literatura cinzenta (2012–2021).

Modelo Desafio-Prática-Ferramenta-Métrica; dimensão global ainda pouco explorada.

Fonte: Rajapakse et al. (2022), *Information and Software Technology*, Elsevier.

Made with GAMMA

MARCO REGULATÓRIO BRASILEIRO

LGPD e Marco Civil definem o dever de proteger dados no Brasil

Segurança de software: obrigação no Brasil, com sanções da ANPD.

LGPD (Lei 13.709/2018) · Art. 46

Exige medidas técnicas e administrativas para proteger dados pessoais desde a concepção (*privacy by design & by default*).

Marco Civil da Internet (Lei 12.965/2014)

Define guarda de logs, sigilo das comunicações e rastreabilidade para auditoria forense.

Impacto Direto na Engenharia

No pipeline: anonimização em homologação, segregação de credenciais e notificação e gestão de incidentes.

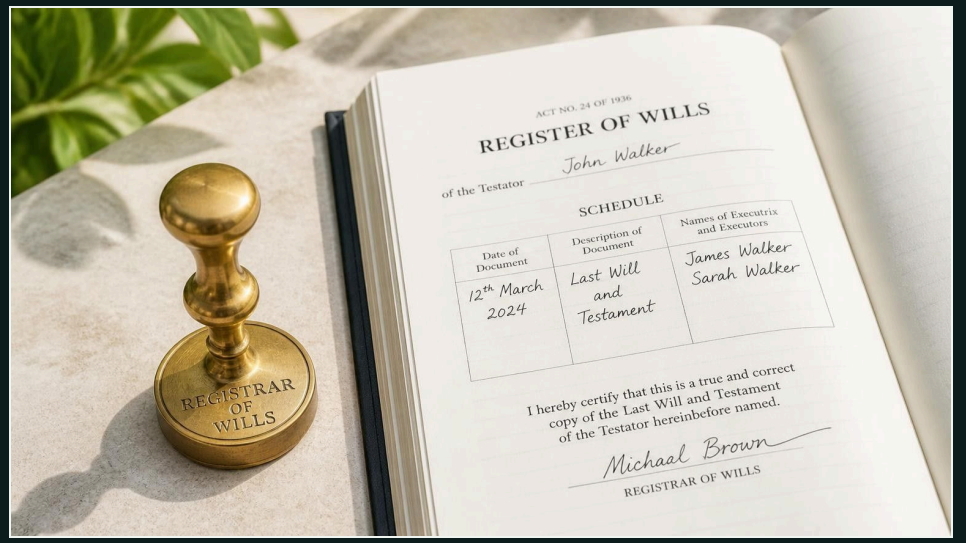


Figura 2. Leis federais impõem rastreabilidade de acessos e blindagem de dados em trânsito e repouso.

Made with GAMMA

NORMAS INTERNACIONAIS

ISO 27001/27002 e NIST SSDF estruturam o ciclo

Normas internacionais oferecem a taxonomia e os controles necessários para auditar cada estágio do pipeline automatizado.

ISO/IEC 27001 & 27002

Governança e Controles

Estrutura o Sistema de Gestão de Segurança da Informação (SGSI). O Anexo A (controle 8.25 a 8.31) dita regras para ciclo de vida de desenvolvimento seguro e segregação de ambientes.

NIST SP 800-218 (SSDF)

Secure Software Framework

Organizado em 4 grupos práticos: Preparar a Organização (PO), Proteger o Software (PS), Produzir Software Bem Protegido (PW) e Responder a Vulnerabilidades (RV).

Mapeamento em CI/CD: SAST e SCA atuam em Produzir (PW); assinatura criptográfica de artefatos atua em Proteger (PS).

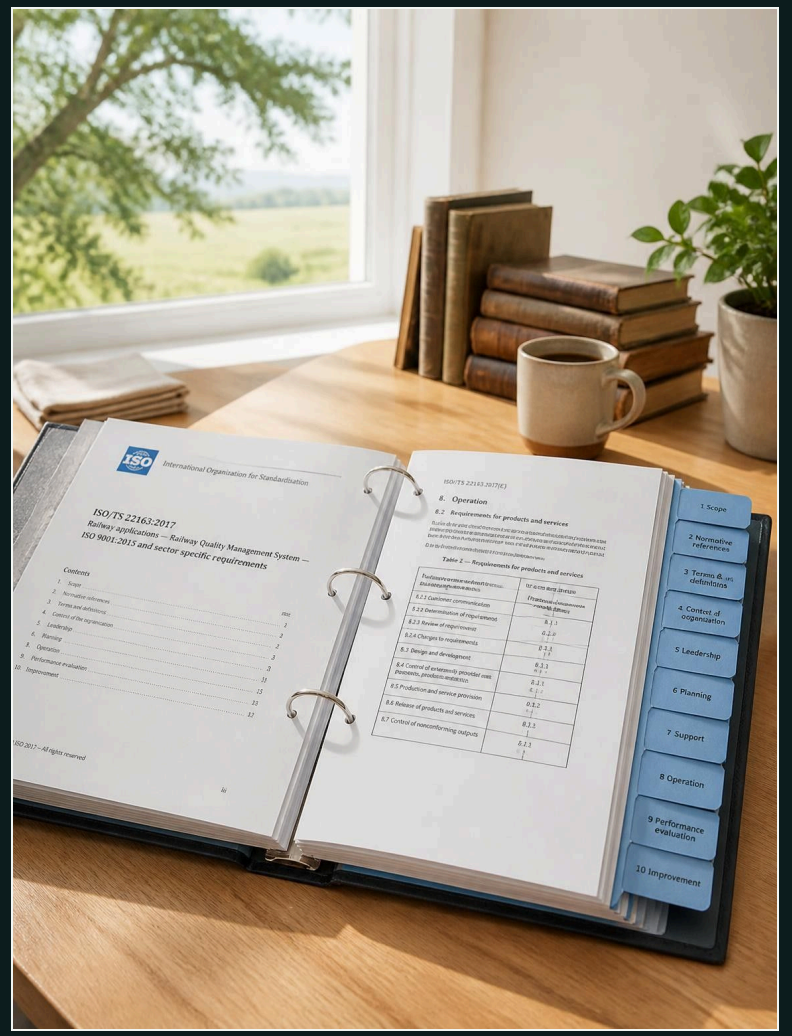


Figura 3. Documentação e auditoria formal de controles em pipelines.

Made with GAMMA

Certificações: do DevSecOps à nuvem

Trilhas de nuvem: AWS e Azure com foco em segurança. Como escolher conforme perfil e carreira.

Certificação	Foco e perfil recomendado
Certified DevSecOps Professional (CDP)	Pipeline seguro, SAST, DAST, SCA e IaC hands-on; engenheiros de software e DevOps.
AWS Certified Security	IAM, KMS, GuardDuty, Security Hub e esteiras AWS; arquitetos de nuvem e SysAdmins.
Azure Security (AZ-500)	Microsoft Defender, Sentinel, Key Vault e GitHub; especialistas em ecossistema híbrido.



Made with GAMMA

SÍNTESE DA AULA E REFERÊNCIAS

Pontos para levar e leituras recomendadas

Três conclusões centrais para a prática profissional de DevSecOps

01 CULTURA & PESSOAS

Pessoas pesam tanto quanto código

Ferramentas automatizadas sem cultura de cooperação geram fadiga de alertas e desvios de processo. Treinamento contínuo é indispensável.

02 GOVERNANÇA & LEI

Alinhe o pipeline às normas

A esteira CI/CD deve gerar evidências auditáveis para comprovar conformidade com LGPD, ISO 27001 e os requisitos do NIST SSDF.

03 EMBASAMENTO CIENTÍFICO

Estudo dos artigos clássicos

Rajapakse et al. (2022) em *Inf. Softw. Technol.* e Zhao et al. (2024) no *ACM Comput. Surv.* devem ser lidos como base teórica.

Pós-Graduação em DevSecOps · Prof. Cloves Rocha · Dúvidas, debates e estudos de caso no ambiente virtual de aprendizagem.

Made with GAMMA